

SECURITY THREAT HUNTING

Rilevamento Malware Avanzato con Regole YARA

STUDENTE Giuseppe Carbone	DATA 04/06/2026	ATTIVITÀ S9-L3-YARA
HOST DI ANALISI FLARE-VM	SISTEMA OPERATIVO TARGET Windows 10 Enterprise (Environment Isolato)	

DESCRIZIONE DELL'ATTIVITÀ

L'obiettivo di questa attività di Threat Hunting consiste nell'individuare un file maligno camuffato all'interno di un'immagine di sistema compromessa (raccolta nella directory `C:\Directory_Sospetta`). Il malware implementa tecniche di evasione modificando il proprio hash crittografico e assumendo un nome apparentemente legittimo per confondersi tra i file di sistema di Windows (es. `taskhost.exe` o `svchost.exe`).

Sulla base dei report di **Threat Intelligence** internazionale, sono stati estratti due Indicatori di Compromissione (IoC) specifici legati al gruppo APT responsabile dell'attacco:

- Una stringa di testo specifica offuscata nel codice binario: `AntiAV_Bypass_2026`
- Una firma esadecimale specifica utilizzata per effettuare memory injection: `{ E2 9A 12 FF }`

OPERAZIONI ESEGUITE

STEP 1 - ANALISI DEGLI IOC E DEFINIZIONE LOGICA

Per intercettare la minaccia a prescindere dal suo nome o dal suo hash, è stata strutturata una regola YARA denominata `Rileva_Finto_Malware`. La logica della regola prevede una condizione di tipo **OR**, attivando il rilevamento qualora venga individuata la stringa di testo OPPURE la sequenza esatta di byte esadecimali.

STEP 2 - SCRITTURA DELLA REGOLA YARA (CACCIA_MALWARE.YAR)

È stato configurato il file `caccia_malware.yar` sul desktop di FLARE-VM. Alla stringa testuale sono stati applicati i modificatori fondamentali per massimizzare l'efficacia del pattern matching:

- `ascii`: per rilevare la stringa codificata in formato caratteri standard a 1 byte.

- wide: per identificare la codifica Unicode a 2 byte (tipica dei binari Windows).
- nocase: per ignorare la distinzione tra lettere maiuscole e minuscole, neutralizzando tentativi elementari di offuscamento.

STEP 3 - ESECUZIONE DELLA SCANSIONE RICORSIVA

Dal prompt dei comandi di FLARE-VM, è stato invocato l'eseguibile a 64-bit di YARA abilitando il flag di ricorsione (-r) per ispezionare approfonditamente tutte le sotto-cartelle presenti nella directory target:

```
yara64.exe -r caccia_malware.yar "New folder"
```

STEP 4 - ANALISI DEI RISULTATI E IDENTIFICAZIONE

La scansione ha prodotto un match positivo immediato, identificando con assoluta certezza la minaccia nascosta sotto falso nome.

TABELLA DI RIFERIMENTO IOC E RILEVAMENTI

INDICATORE (IOC)	TIPO	PROPRIETÀ / MODIFICATORI	ESITO SCANSIONE
AntiAV_Bypass_2026	Stringa di Testo	ascii wide nocase	MATCH TROVATO
E2 9A 12 FF	Sequenza Byte (Hex)	Memory Injection Pattern	CONFIGURATO (OR)
updater_service.exe	File Maligno Isolato	Percorso: System32\drivers\	RILEVATO

EVIDENZE DI LABORATORIO (SCREENSHOT)

EVIDENZA 1 - CONFIGURAZIONE DELLA REGOLA YARA (CACCIA_MALWARE.YAR)

Visualizzazione della struttura sintattica corretta della regola all'interno della FLARE-VM:

```
rule Rileva_Finto_Malware {  
  strings:  
    $caccia_malware = "AntiAV_Bypass_2026" ascii wide nocase  
    $hex_injection = { E2 9A 12 FF }  
  
  condition:  
    $caccia_malware or $hex_injection  
}
```

EVIDENZA 2 - OUTPUT DI RILEVAMENTO DELLA SCANSIONE DA CONSOLE

Esecuzione ricorsiva del comando e intercettazione del payload malevolo:

```
FLARE-VM Thu 06/04/2026 7:18:39.54  
C:\Users\FlareVm\Desktop>yara64.exe -r caccia_malware.yar "New folder"  
Rileva_Finto_Malware New folder\Flare_Incident_Drive\Windows\System32\drivers\updater_service.exe  
  
FLARE-VM Thu 06/04/2026 7:22:20.73  
C:\Users\FlareVm\Desktop>
```

CONCLUSIONI E MITIGAZIONE

Il file identificato, **updater_service.exe**, posizionato ingannevolmente nella directory dei driver critici di Windows (System32\drivers\), rappresenta una minaccia ad alto rischio legata a un tool di bypass delle difese antivirus (AntiAV).

Grazie all'impiego delle firme comportamentali e statiche fornite dalle regole YARA, l'attività di Incident Response ha permesso di scoprire l'esatta posizione del file nonostante i tentativi di camuffamento dell'hash e del nome operati dall'attore di minaccia (APT). Il file è pronto per essere isolato e sottoposto ad analisi dinamica (sandbox).